MSM ACADEMY

SECTION 2

ISO/IEC 27001:2022
Clauses 1–10



2.0 Introduction
2.1 Clauses 1–3
2.2 Clause 4 · Context
2.3 Clause 5 · Leadership
2.4 Clause 6 · Planning
2.5 Clause 7 · Support
2.6 Clause 8 · Operation
2.7 Clause 9 · Performance evaluation
2.8 Clause 10 · Improvement

LESSON 2.0

How the standard is organized

Clauses 1–3

The frame

Scope of the standard, the one normative reference, and where the terms come from. Nothing to implement.

Clauses 4–10

The requirements

Everything an organization must do to conform. None of them can be excluded.

Annex A

The controls reference

93 controls. Normative, and used together with the risk treatment requirements in 6.1.3.

The 2022 edition follows the harmonized structure shared by ISO management system standards.

Clauses 4–10 as a management cycle

Plan	Do	Check	Act
Clauses 4, 5, 6	**Clauses 7, 8**	**Clause 9**	**Clause 10**
Context, leadership, risks and objectives	Support and operation	Monitoring, internal audit, management review	Continual improvement and corrective action

A navigation aid, not a requirement: the standard does not present its clauses as a PDCA cycle.

LESSON 2.0

Reading the requirements

Five reading rules

1. “Shall” marks a requirement: what conformity is assessed against.
2. “Should” is a recommendation, “may” a permission, “can” a possibility.
3. NOTEs explain or give examples. They never add a requirement.
4. Clause order is not implementation order, and lettered lists are not ranked.
5. Documented-information wording matters: “available as documented information” requires controlled documented information to exist; “retain documented information” requires evidence to be kept.

LESSON 2.0

Amendment 1:2024

What the amendment changed

4.1 A new requirement: determine whether climate change is a relevant issue.

4.2 A new NOTE: interested parties can have requirements related to climate change.

- Nothing else changed. Annex A and all other clauses are as published in 2022.

How each clause is taught

For every significant requirement

1. The requirement: an accurate paraphrase of every item.
2. What it means, and the items broken down where there are several.
3. A practical example from a real kind of organization.
4. Two perspectives: the implementer’s and the auditor’s.
5. Common challenges, then a short recap and a knowledge check.

Two ways to read every requirement

The same clause, seen from both sides of the table.

Implementer's view

- What must we determine, decide or establish?
- How does it connect to the rest of the ISMS?
- What has to be kept up to date?

Auditor's view

- What does the requirement actually ask?
- What evidence would show it is met?
- Where does it usually break down?

MSM ACADEMY

SECTION 2 · LESSON 2.1

Clauses 1–3: the frame

Scope, normative reference, and terms and definitions.



LESSON 2.1 · CLAUSE 1

Clause 1: Scope

What Clause 1 says (paraphrased)

- The standard specifies requirements to establish, implement, maintain and continually improve an ISMS.
- It includes requirements to assess and treat information security risks, tailored to the organization.
- The requirements are generic: for all organizations, whatever their type, size or nature.
- No requirement in Clauses 4–10 may be excluded when claiming conformity.

LESSON 2.1 · CLAUSE 1

What Clause 1 means

A risk-based system

Not a checklist. Controls follow from the organization’s own risks.

One standard for all

A five-person consultancy and a global bank use the same requirements, applied to very different realities.

Clauses vs controls

Clause requirements: none excluded. Annex A controls: excluded only with justification.

Clause 2: Normative references

What Clause 2 says (paraphrased)

- One normative reference: ISO/IEC 27000, the overview and vocabulary standard.
- It is undated, so the latest edition (with any amendments) applies.
- The other ISO/IEC 27000-family standards are useful guidance, not normative references.

Clause 3: Terms and definitions

What Clause 3 says, and why it matters

- All terms and definitions come from ISO/IEC 27000.
- Words like “risk owner”, “interested party” and “nonconformity” carry those defined meanings.
- Shared definitions keep IT, legal, HR, management and auditors reading a requirement the same way.

Clauses 1–3: two perspectives

The frame shapes how every later requirement is read.

Implementer's view

- Build a risk-based system, not a checklist
- Use the ISO/IEC 27000 vocabulary in ISMS documents
- Plan for all of Clauses 4–10 from the start

Auditor's view

- Expect every clause requirement to be addressed
- Read terms as ISO/IEC 27000 defines them
- Distinguish clause requirements from Annex A controls

Check your understanding

A small company says it will not run internal audits because it is “too small for Clause 9.2”.

A Acceptable: small organizations may exclude clause requirements

B Acceptable if the exclusion is justified in the SoA

C Not acceptable: no requirement in Clauses 4–10 can be excluded

D Not acceptable unless an Annex A control requires audits

Check your understanding

A small company says it will not run internal audits because it is “too small for Clause 9.2”.

A. Acceptable: small organizations may exclude clause requirements

B. Acceptable if the exclusion is justified in the SoA

C. **Not acceptable: no requirement in Clauses 4–10 can be excluded**

D. Not acceptable unless an Annex A control requires audits

Answer: C

Clause 1: excluding any requirement in Clauses 4–10 is not acceptable when claiming conformity. Size changes how, not whether.

MSM ACADEMY

SECTION 2 · LESSON 2.2

Clause 4: Context of the organization

2.2

Issues, interested parties, scope and the ISMS itself.

LESSON 2.2 · CLAUSE 4.1

4.1 The organization and its context

What the clause requires (paraphrased)

- Determine the external and internal issues relevant to the organization’s purpose…
- …that affect its ability to achieve the intended outcomes of the ISMS.
- Determine whether climate change is a relevant issue (Amendment 1:2024).

NOTE: this is the external and internal context described in ISO 31000:2018, 5.4.1.

What 4.1 means

External issues

Laws and regulation, customer and market pressure, the threat landscape, technology change, suppliers, the physical environment.

Internal issues

Strategy, structure, culture, legacy systems, skills and resources, recent restructuring, current security maturity.

Why it matters

Issues feed the scope, the risk assessment and the objectives. They are inputs, not a document for its own sake.

4.1 in a regional hospital

Healthcare

The situation

- External: patient-data law, a national cyber-security directive, ransomware attacks on other hospitals
- Internal: clinical systems that cannot be patched quickly, high staff turnover, a recent merger of two IT teams

Applying the requirement

- Each issue is recorded with why it matters to information security
- Unpatchable clinical systems and ransomware flow straight into the risk assessment
- The merger shapes the scope and the roles in Clause 5

Climate change in Clause 4

4.1 · Requirement

Determine whether climate change is a relevant issue.

A decision the organization must make and be able to support.

4.2 · NOTE 2

Interested parties can have requirements related to climate change.

Guidance only. It adds no requirement.

Example: a data centre in a flood plain, or offices that lose power in heatwaves, make “relevant” the supportable answer.

LESSON 2.2 · CLAUSE 4.2

4.2 Needs and expectations of interested parties

What the clause requires (paraphrased)

a) Determine the interested parties relevant to the ISMS.

b) Determine the relevant requirements of these interested parties.

c) Determine which of these requirements will be addressed through the ISMS.

NOTE 1: requirements can include legal and regulatory requirements and contractual obligations. NOTE 2: see climate change.

4.2 a) and b): parties and their requirements

Who, and what they need

a) An interested party can affect, be affected by, or perceive itself affected by the organization’s information security.

- Customers, regulators, employees, suppliers, shareholders, insurers, partners.

b) Requirements: a customer’s contract clause, a regulator’s reporting rule, staff expectations of privacy.

4.2 c): deciding what the ISMS addresses

A deliberate decision

- Legal, regulatory and contractual requirements will normally be addressed.
- Other expectations may be addressed, or recorded as not taken on, with a reason.
- Example: a customer asks for in-country hosting it has not contracted for. The organization may decide not to adopt it.

4.2 in a payment-services firm

Financial services

The situation

- Parties: card schemes, the central bank, merchants, cardholders, a cloud provider, staff
- Requirements: card-industry security rules, incident reporting within 24 hours, merchant contract clauses

Applying the requirement

- A register of parties and their requirements, each with its source
- Each requirement marked “addressed through the ISMS” or not, with the reason
- Reviewed when contracts or regulations change

4.1 and 4.2: two perspectives

Context and interested parties drive everything that follows.

Implementer's view

- Determine issues with the people who know the business
- Trace each requirement to its source
- Record what the ISMS will and will not address
- Review when the business changes

Auditor's view

- Are issues and requirements specific to this organization?
- Is the climate decision supportable?
- Do they visibly feed scope, risks and objectives?
- Have they been kept up to date?

LESSON 2.2 · CLAUSE 4.3

4.3 Scope of the ISMS

What the clause requires (paraphrased)

- Determine the boundaries and applicability of the ISMS to establish its scope, considering:

a) the external and internal issues from 4.1;

b) the requirements from 4.2;

c) interfaces and dependencies between its own activities and those performed by other organizations.

- The scope shall be available as documented information.

4.3 a) and b): scope follows context

The scope is a consequence, not a starting point

a) Issues shape it: a regulated product line, a new acquisition, a risky legacy site.

b) Requirements shape it: a customer contract that names a service; a law that covers certain data.

- A scope drawn first and justified later usually leaves something important outside.

4.3 c): interfaces and dependencies

Where the organization meets others

- Outsourced hosting: the provider runs the data centre, but the information in it stays in scope.
- Excluded sites or units that exchange information with in-scope ones are interfaces to control.
- Define who is responsible on each side of every interface.

4.3 in a manufacturing group

Manufacturing

The situation

- Three plants and a head office; certification needed for the design centre that holds customer drawings
- Design files are stored in a cloud service; one plant shares a network with the design centre

Applying the requirement

- Scope: the design centre, its cloud service and the shared network segment
- The other plants excluded, with the reason recorded
- The cloud provider and the shared network documented as interfaces with responsibilities

LESSON 2.2 · CLAUSE 4.3

The documented scope

A scope statement that works

- Names the organizational units, locations, services and information covered.
- States any exclusions and why they do not undermine the ISMS.
- Identifies the key interfaces and dependencies.
- Is available as documented information and kept current.

Scope: two perspectives

Clause 4.3: the boundary everything else depends on.



Implementer's view

- Derive the scope from 4.1 and 4.2
- Map every interface and dependency
- Justify every exclusion
- Keep the scope statement current



Auditor's view

- Can the scope be traced to issues and requirements?
- Do the excluded parts really not affect it?
- Are interfaces identified and controlled?
- Does practice match the written scope?

LESSON 2.2 · CLAUSE 4.4

4.4 Information security management system

What the clause requires (paraphrased)

- Establish, implement, maintain and continually improve an ISMS…
- …including the processes needed and their interactions…
- …in accordance with the requirements of the standard.

4.4 in an online payment platform

SaaS

The situation

- Access control for developers, vulnerability scanning, secure coding, encryption, incident response
- Each was introduced separately by a different team

Applying the requirement

- Map the processes and how they feed each other
- Scan results feed the risk register; incidents feed corrective action
- Keep the system working and improving, not just documented

Clause 4: common challenges

Where organizations go wrong

1. Generic lists of issues and parties, copied from a template.
2. Context written once and never reviewed.
3. A scope chosen for convenience, with unexplained exclusions.
4. Interfaces with suppliers and excluded units not identified.
5. Climate change decided without any supporting reasoning.

LESSON 2.2 · RECAP

Clause 4 recap

- 4.1: issues relevant to purpose, including a supportable climate decision
- 4.2: parties, their requirements, and which ones the ISMS addresses
- 4.3: a documented scope derived from 4.1 and 4.2, with interfaces identified
- 4.4: an ISMS of connected processes, maintained and improved

Check your understanding

A company says: “Climate change isn’t relevant to us.” Its only data centre sits in a flood zone.

A Nonconformity: climate change is always a relevant issue

B Acceptable: the decision belongs to the organization alone

C The determination must be supportable; this one looks hard to support

D Not an audit matter: Amendment 1 only added a NOTE

Check your understanding

A company says: “Climate change isn’t relevant to us.” Its only data centre sits in a flood zone.

A. Nonconformity: climate change is always a relevant issue

B. Acceptable: the decision belongs to the organization alone

C. The determination must be supportable; this one looks hard to support

D. Not an audit matter: Amendment 1 only added a NOTE

Answer: C

4.1 requires a determination, not a fixed answer. A flood-zone data centre makes “not relevant” hard to support.

MSM ACADEMY

SECTION 2 · LESSON 2.3

Clause 5: Leadership

Commitment, policy, and roles with real authority.



5.1 Leadership and commitment

Top management demonstrates leadership by (paraphrased)

a) Ensuring the policy and objectives exist and fit the strategic direction.

b) Ensuring ISMS requirements are integrated into the organization’s processes.

c) Ensuring the resources needed for the ISMS are available.

d) Communicating the importance of effective security and of conforming to the ISMS.

5.1 Leadership and commitment

…and by (paraphrased)

e) Ensuring the ISMS achieves its intended outcomes.

f) Directing and supporting people to contribute to its effectiveness.

g) Promoting continual improvement.

h) Supporting other management roles to show leadership in their own areas.

NOTE: “business” can be read broadly as the activities core to the organization’s purpose.

What the eight items add up to

Direction (a, b)

Security aligned with strategy and built into normal processes, from HR to procurement, not a separate silo.

Enablement (c, d, f)

Resources made available; the importance of security communicated; people directed and supported.

Results (e, g, h)

Leaders own the outcomes, push improvement, and expect other managers to lead in their own areas.

5.1 in a logistics company

Logistics

The situation

- The board is moving the business to cloud-based tracking services
- Security has been seen as an IT matter

Applying the requirement

- The board sets security objectives that support the cloud strategy
- Security requirements are built into supplier selection and project approval
- Budget is approved for training and monitoring; the CEO briefs managers

5.2 Policy: what it must contain

Top management establishes a policy that (paraphrased)

a) Is appropriate to the purpose of the organization.

b) Includes security objectives, or provides the framework for setting them.

c) Includes a commitment to satisfy applicable requirements related to information security.

d) Includes a commitment to continual improvement of the ISMS.

5.2 Policy: how it is handled

The policy shall (paraphrased)

e) Be available as documented information.

f) Be communicated within the organization.

g) Be available to interested parties, as appropriate.

What 5.2 means

Tailored, not generic

A fintech and a logistics firm write very different policies, because their purposes differ.

A framework for action

The policy links to measurable objectives, such as reducing phishing incidents.

One top-level policy

Topic-specific policies sit beneath it, under Annex A control 5.1.

5.2 in a government agency

Public sector

The situation

- The agency adopted a two-page policy from another department
- It mentions services the agency does not provide

Applying the requirement

- Rewrite it around the agency’s own purpose and legal duties
- State the objectives framework and both commitments
- Communicate it at induction and on the intranet; publish a summary for citizens

LESSON 2.3 · CLAUSE 5.3

5.3 Roles, responsibilities and authorities

Top management shall (paraphrased)

- Ensure responsibilities and authorities for security roles are assigned and communicated.

a) Assign responsibility and authority for the ISMS conforming to the standard.

b) Assign responsibility and authority for reporting ISMS performance to top management.

NOTE: top management can also assign reporting responsibilities within the organization.

What 5.3 means

Assigned and communicated

From system administrators to department heads, people know their security duties.

Responsibility with authority

A role without the authority to act cannot deliver what it is responsible for.

A typical model

An information security manager handles a) and b), reporting to top management.

Leadership: two perspectives

Clause 5: commitment is shown through decisions.

Implementer's view

- Give top management real decisions to make
- Tailor the policy and link it to objectives
- Match every responsibility with authority
- Assign a) and b) explicitly

Auditor's view

- Interview top management, not only the ISMS manager
- Look for decisions, not declarations
- Check the policy fits and reached people
- Check roles are known in practice

Clause 5: common challenges

Where organizations go wrong

1. A signed policy is the only evidence of commitment.
2. A template policy that says nothing about this organization.
3. Security delegated entirely to IT, with no top-management involvement.
4. Responsibilities assigned without the authority to act on them.

LESSON 2.3 · RECAP

Clause 5 recap

- 5.1: eight ways top management shows leadership; activities delegated, accountability retained
- 5.2: a tailored policy with objectives, two commitments, and planned communication
- 5.3: roles assigned and communicated, with responsibility for conformity and reporting

Check your understanding

An auditor finds roles clearly assigned in meetings and emails, but no role descriptions document.

A Conforming if roles are assigned and communicated

B Nonconformity with 5.3: roles must be documented

C Nonconformity with 5.2: the policy must list roles

D Observation only: the standard is silent on roles

Check your understanding

An auditor finds roles clearly assigned in meetings and emails, but no role descriptions document.

A **Conforming if roles are assigned and communicated**

B Nonconformity with 5.3: roles must be documented

C Nonconformity with 5.2: the policy must list roles

D Observation only: the standard is silent on roles

Answer: A

5.3 requires roles to be assigned and communicated. It does not require a specific document, so the evidence can conform.

MSM ACADEMY

SECTION 2 · LESSON 2.4

Clause 6: Planning

Risks and opportunities, risk assessment and treatment, objectives, and planned change.



6.1.1 Actions to address risks and opportunities

When planning the ISMS, the organization shall (paraphrased)

- Consider the issues from 4.1 and the requirements from 4.2, and determine the risks and opportunities that need addressing to:

a) ensure the ISMS can achieve its intended outcomes;

b) prevent, or reduce, undesired effects;

c) achieve continual improvement.

6.1.1 Planning the actions

The organization shall plan (paraphrased)

d) Actions to address these risks and opportunities.

e) 1) How to integrate and implement the actions into its ISMS processes.

e) 2) How to evaluate the effectiveness of these actions.

Two kinds of risk in Clause 6



6.1.1: system-level

Risks and opportunities for the ISMS itself, such as weak leadership support or a new tool that could improve monitoring.



6.1.2–6.1.3: information security risks

Risks to the confidentiality, integrity and availability of information in scope.



Why the difference matters

Both are required. Only the second has the full assessment process and the SoA.

6.1.2 Information security risk assessment

Define and apply a risk assessment process that (paraphrased)

a) Establishes and maintains risk criteria.

b) Produces consistent, valid and comparable results.

c) Identifies the risks and their owners.

d) Analyses the risks.

e) Evaluates the risks.

6.1.2 a) Risk criteria

Two sets of criteria

1) Risk acceptance criteria: how much risk the organization is prepared to accept, and who may accept it.

2) Criteria for performing risk assessments: scales for consequence and likelihood, and how levels are worked out.

- Example: a bank decides any High risk to customer data must be treated, and only a director may accept a Medium.

6.1.2 b) Consistent, valid, comparable

Repeatable results

- Two assessors looking at the same risk should reach broadly the same rating.
- This year’s assessment can be compared with last year’s.
- Achieved through defined scales, examples and calibration, not individual judgement alone.

6.1.2 c) Identifying the risks

The process shall

1) Identify risks associated with loss of confidentiality, integrity and availability of information in scope.

2) Identify the risk owners.

- Example: a hospital’s cloud patient records. An outage affects availability; unauthorized access affects confidentiality.

6.1.2 d) Analysing the risks

The process shall

1) Assess the potential consequences if the risk materializes.

2) Assess the realistic likelihood of it occurring.

3) Determine the level of risk.

- Example: stolen design files at a manufacturer: high consequence, medium likelihood.

6.1.2 e) Evaluating the risks

The process shall

1) Compare the analysis results with the risk criteria from a).

2) Prioritize the analysed risks for risk treatment.

- Documented information about the risk assessment process shall be retained.

From assessment to approved treatment

1	**Identify**	Risks to confidentiality, integrity, availability; owners	6.1.2 c)
2	**Analyse**	Consequence, likelihood, level	6.1.2 d)
3	**Evaluate**	Compare with criteria, prioritize	6.1.2 e)
4	**Treat**	Choose options and controls	6.1.3 a)–b)
5	**Check**	Compare with Annex A; produce the SoA	6.1.3 c)–d)
6	**Approve**	Plan approved, residual risk accepted	6.1.3 e)–f)

Rows 1–3 assess (6.1.2). **Rows 4–6** treat (6.1.3).

6.1.2 in an e-commerce business

E-commerce

The situation

- Risk: unauthorized access to customer accounts through stolen passwords
- Recent credential-stuffing attacks on similar shops

Applying the requirement

- Owner: the head of e-commerce operations
- Consequence high (customer harm, fines), likelihood high (active attacks): level High
- Above the threshold, so prioritized for treatment; all recorded

6.1.3 Information security risk treatment

Define and apply a risk treatment process to (paraphrased)

a) Select appropriate treatment options, taking account of the assessment results.

b) Determine all controls necessary to implement the chosen options.

c) Compare them with Annex A and verify no necessary control is omitted.

d) Produce a Statement of Applicability.

e)–f) Formulate a treatment plan; obtain risk owners’ approval and acceptance of residual risk.

6.1.3 a) Selecting treatment options

Options commonly used in this course (from ISO/IEC 27005)

Modify Change the likelihood or consequence with controls.

Retain Accept the risk as it is, within the acceptance criteria.

Avoid Stop the activity that gives rise to the risk.

Share Share it with another party, for example through insurance or a contract.

The standard requires options to be selected; it does not list them. These four are guidance, not requirements.

6.1.3 b) and c) Determining and checking controls

Controls come first; Annex A checks them

b) Determine all controls needed for the chosen options. NOTE 1: from any source, or designed as required.

c) Compare with Annex A and verify no necessary control is omitted.

- NOTE 2–3: Annex A is a list of possible controls, not exhaustive; others can be added.

6.1.3 d) The Statement of Applicability

The SoA contains

- The necessary controls (from b and c).
- The justification for their inclusion.
- Whether the necessary controls are implemented or not.
- The justification for excluding any Annex A controls.

An SoA exclusion that holds up

Professional services

The situation

- A consultancy runs entirely on cloud services
- It has no server room, but its two offices hold laptops and paper client files

Applying the requirement

- Controls for securing equipment rooms: excluded, “no on-premises equipment rooms in scope”
- Physical entry and clear desk controls: included, because offices and paper files are in scope
- Each line traces to the risk assessment

6.1.3 e) and f) Plan and approval

From decision to commitment

e) Formulate a risk treatment plan: actions, responsibilities, resources, timescales.

f) Risk owners approve the plan and accept the residual risks.

- Retain documented information about the risk treatment process.

NOTE 4: the assessment and treatment process aligns with the principles and guidelines of ISO 31000.

Risk and the SoA: two perspectives

Clauses 6.1.2 and 6.1.3.

Implementer's view

- Define criteria before assessing
- Make results repeatable
- Trace every SoA line to a risk or requirement
- Get owners’ approval and acceptance on record

Auditor's view

- Are criteria defined and actually used?
- Would a second assessor reach similar ratings?
- Is each inclusion and exclusion justified?
- Did the right owners approve and accept?

LESSON 2.4 · CLAUSE 6.2

6.2 Information security objectives

Objectives at relevant functions and levels shall (paraphrased)

a) Be consistent with the information security policy.

b) Be measurable, if practicable.

c) Take into account security requirements and risk assessment and treatment results.

d) Be monitored.

6.2 Information security objectives

…and shall (paraphrased)

e) Be communicated.

f) Be updated as appropriate.

g) Be available as documented information.

- Documented information on the objectives shall be retained.

What 6.2 means

Grounded in real needs

Built from requirements and the risk results, not generic best practice.

Measurable where practicable

“Reduce successful phishing by 40% in 12 months”, not “improve awareness”.

Alive, not filed

Monitored, communicated and updated as the risk picture changes.

LESSON 2.4 · CLAUSE 6.2

6.2 Planning to achieve objectives

When planning how to achieve them, determine

- **h)** What will be done.
- **i)** What resources will be required.
- **j)** Who will be responsible.
- **k)** When it will be completed.
- **l)** How the results will be evaluated.

6.2: an objective and its plan

Any organization

The situation

- Objective: reduce successful phishing by 40% within 12 months
- Linked to the policy and to a High risk in the assessment

Applying the requirement

- What: monthly simulations, interactive training, better email filtering
- Resources: platform licence, filter upgrade, IT and HR time
- Who: the security manager, with IT and HR
- When: six months, with monthly milestones
- Evaluated by: click rates, training completion, incident counts

Objectives: two perspectives

Clause 6.2.



Implementer's view

- Set objectives where the work is done
- Derive them from policy and risk results
- Give each one a plan: h) to l)
- Monitor and update them



Auditor's view

- Are objectives set at relevant levels?
- Can each be traced to policy or risk?
- Is progress actually monitored?
- Do people know their objectives?

LESSON 2.4 · CLAUSE 6.3

6.3 Planning of changes

What the clause requires

- When the organization determines the need for changes to the ISMS, they shall be carried out in a planned manner.
- New in the 2022 edition.
- Planning typically considers the purpose, risks, resources, responsibilities and effect on the rest of the ISMS.

6.3 in a software company

SaaS

The situation

- The company acquires a smaller firm and decides to bring it into the ISMS scope
- Different tools, policies and roles

Applying the requirement

- Plan the scope change, risk assessment and policy alignment
- Assign responsibilities and a timeline
- Update the scope statement, SoA and objectives when complete

Clause 6: common challenges

Where organizations go wrong

1. Risks assessed before any criteria are defined.
2. Annex A used as the starting list instead of a cross-check.
3. SoA exclusions justified generically, not from scope and risk.
4. Residual risk accepted by someone without the authority.
5. Objectives that cannot be measured, or are never monitored.

LESSON 2.4 · RECAP

Clause 6 recap

- 6.1.1: risks and opportunities for the ISMS, with planned and evaluated actions
- 6.1.2: criteria, then identify, analyse and evaluate risks, repeatably
- 6.1.3: options, controls, Annex A check, SoA, plan, owner approval
- 6.2: measurable objectives with a plan; 6.3: changes to the ISMS planned

Check your understanding

An SoA excludes a physical security monitoring control: “We are a cloud-only business.” The scope includes two offices.

A Acceptable: physical controls never apply to cloud businesses

B Acceptable if the cloud provider holds ISO/IEC 27001

C A nonconformity: Annex A controls can never be excluded

D Questionable: exclusions must be justified from scope and risk

Check your understanding

An SoA excludes a physical security monitoring control: “We are a cloud-only business.” The scope includes two offices.

A. Acceptable: physical controls never apply to cloud businesses

B. Acceptable if the cloud provider holds ISO/IEC 27001

C. A nonconformity: Annex A controls can never be excluded

D. Questionable: exclusions must be justified from scope and risk

Answer: D

6.1.3 d) requires a justification for each exclusion. Offices in scope make a blanket “cloud-only” reason hard to support.

MSM ACADEMY

SECTION 2 · LESSON 2.5

Clause 7: Support

Resources, competence, awareness, communication and documented information.

2.5

LESSON 2.5 · CLAUSE 7.1

7.1 Resources

What the clause requires (paraphrased)

- Determine and provide the resources needed to establish, implement, maintain and continually improve the ISMS.

- Resources include people, time, budget, tools, infrastructure and external expertise.

7.1 in a financial services company

Financial services

The situation

- The company decides to introduce multi-factor authentication for every user
- The project needs licences, integration work, user support and ongoing administration

Applying the requirement

- Determine the resources: licences, engineering time, help-desk capacity
- Provide them through an approved budget and staffing plan
- Plan the ongoing cost, not just the roll-out

LESSON 2.5 · CLAUSE 7.2

7.2 Competence

The organization shall (paraphrased)

a) Determine the competence needed by people doing work under its control that affects security performance.

b) Ensure they are competent, on the basis of education, training or experience.

c) Where applicable, act to acquire the competence, and evaluate whether the actions worked.

d) Retain appropriate documented information as evidence of competence.

NOTE: actions can include training, mentoring, re-assignment, or hiring or contracting competent people.

7.2 for a key-management role

Any organization

The situation

- An engineer is promoted to manage encryption keys
- She has not done this before

Applying the requirement

- a) Competence defined: key lifecycle, the organization’s procedures, incident handling
- c) Training and a mentoring period; effectiveness checked by a supervised key rotation
- d) Records of the training and the supervised task retained

7.3 Awareness

People doing work under the organization’s control shall be aware of (paraphrased)

a) The information security policy.

b) Their contribution to the ISMS’s effectiveness, including the benefits of improved security performance.

c) The implications of not conforming with ISMS requirements.

LESSON 2.5 · CLAUSE 7.3

What 7.3 means

For everyone

Employees, contractors and temporary staff, from the receptionist to the board.

Why it matters

One person clicking a phishing link, or skipping a patch, can undermine the whole system.

How it is shown

People can explain the policy, their part in it, and what happens if it is not followed.

7.4 Communication

Determine the need for internal and external communications, including (paraphrased)

a) On what to communicate.

b) When to communicate.

c) With whom to communicate.

d) How to communicate.

7.4 in an IT services company

IT services

The situation

- The company is introducing a new remote-access method
- Staff, customers' IT teams and the help desk are affected

Applying the requirement

- What: the new method, timing and support
- When: two weeks before the change, and on the day
- With whom: staff, customer IT contacts, the help desk
- How: email, a short guide, and a briefing for help-desk staff

7.5.1 Documented information: general

The ISMS shall include (paraphrased)

a) Documented information required by the standard.

b) Documented information the organization determines is necessary for the ISMS to be effective.

NOTE: the extent differs with size and activities, complexity of processes, and people's competence.

What 7.5.1 means

No fixed document set

Beyond what the standard requires, the organization decides what it needs.

Proportionate

A multinational bank needs far more documentation than a ten-person IT support firm.

Competence reduces documents

Experienced, competent people may need fewer step-by-step procedures.

7.5.2 Creating and updating

Ensure appropriate (paraphrased)

a) Identification and description: for example a title, date, author or reference number.

b) Format and media: for example language, software version, graphics; paper or electronic.

c) Review and approval for suitability and adequacy.

7.5.3 Control of documented information

Documented information shall be controlled to ensure (paraphrased)

a) It is available and suitable for use, where and when it is needed.

b) It is adequately protected, for example from loss of confidentiality, improper use or loss of integrity.

7.5.3 Control activities

Address, as applicable (paraphrased)

c) Distribution, access, retrieval and use.

d) Storage and preservation, including legibility.

e) Control of changes, for example version control.

f) Retention and disposition.

- External documents needed for the ISMS are identified and controlled.

NOTE: access can mean permission to view only, or to view and change.

Support: two perspectives

Clause 7: the conditions for the ISMS to work.

Implementer's view

- Budget for operation, not just the project
- Define competence by role; check training worked
- Plan communication before it is needed
- Document what is needed, and control it

Auditor's view

- Were the resources actually provided?
- Is there evidence of competence for key roles?
- Can staff explain the policy and their part?
- Is the current version in use, and protected?

Clause 7: common challenges

Where organizations go wrong

1. Training records exist, but competence for key roles is never defined.
2. Awareness reduced to an annual click-through course.
3. Contractors left out of competence and awareness.
4. Excessive documentation that nobody follows, or too little to run consistently.
5. Old versions in circulation; external documents out of date.

Clause 7 recap

- 7.1: resources determined and provided for the whole ISMS life
- 7.2: competence defined, achieved, evaluated and evidenced
- 7.3–7.4: everyone aware; communication planned: what, when, whom, how
- 7.5: required and necessary documents, created well and controlled

Check your understanding

Every employee completed security training, but nobody has defined the competence needed for the incident response team.

A Conforming: training records are evidence of competence

B A gap against 7.2 a): competence needs are not determined

C A gap against 7.3: awareness is incomplete

D Conforming: 7.2 applies only to the ISMS manager

Check your understanding

Every employee completed security training, but nobody has defined the competence needed for the incident response team.

A. Conforming: training records are evidence of competence

B. A gap against 7.2 a): competence needs are not determined

C. A gap against 7.3: awareness is incomplete

D. Conforming: 7.2 applies only to the ISMS manager

Answer: B

7.2 a) requires the necessary competence to be determined first. Training records alone do not show that the right competence exists.

MSM ACADEMY

SECTION 2 · LESSON 2.6

Clause 8: Operation

Running the processes, and carrying out the risk work that Clause 6 planned.

2.6

LESSON 2.6 · CLAUSE 8.1

8.1 Operational planning and control

Plan, implement and control the needed processes, by (paraphrased)

- Processes needed to meet requirements and carry out the Clause 6 actions.
- Establishing criteria for the processes.
- Implementing control of the processes in accordance with the criteria.
- Documented information shall be available to the extent needed to have confidence the processes ran as planned.

LESSON 2.6 · CLAUSE 8.1

8.1 Changes and external providers

The organization shall also (paraphrased)

- Control planned changes, and review the consequences of unintended changes, mitigating adverse effects as necessary.

- Ensure that externally provided processes, products or services relevant to the ISMS are controlled.

8.1 for user access

Any organization

The situation

- Process: granting access to business systems
- Part of the help desk is outsourced

Applying the requirement

- Criteria: role verified, manager approval, least privilege, request logged
- Control: the ticketing system enforces approval before access is granted
- Evidence: logged requests and approvals
- The outsourced help desk follows the same criteria, set in its contract

8.2 and 8.3: risk work in operation

What the clauses require (paraphrased)

8.2 Perform risk assessments at planned intervals, or when significant changes are proposed or occur, using the 6.1.2 a) criteria; retain the results.

8.3 Implement the risk treatment plan; retain the results of the risk treatment.

Clause 6 plans, Clause 8 does

Define

6.1.2 / 6.1.3

The process and criteria for assessing and treating risk

›

Assess

8.2

Run it at planned intervals and on significant change

›

Treat

8.3

Carry out the treatment plan

›

Keep

8.2 / 8.3

Retain the results as evidence

An organization can have a perfect method in Clause 6 and still fail Clause 8 by never running it.

Operation: two perspectives

Clause 8: the plan in motion.

Implementer's view

- Set criteria for each process
- Build control into how work is done
- Reassess risk when something significant changes
- Control outsourced processes through contracts and checks

Auditor's view

- Do processes run as their criteria say?
- Is there evidence they ran as planned?
- Was risk reassessed after the last major change?
- Is the treatment plan progressing?

Clause 8: common challenges

Where organizations go wrong

1. Risk assessment done once for certification, then never repeated.
2. Significant changes made without reassessing risk.
3. Treatment plans with actions long overdue and no follow-up.
4. Outsourced services assumed to be the provider’s problem.

LESSON 2.6 · RECAP

Clause 8 recap

- 8.1: criteria, control, evidence, change control and external providers
- 8.2: risk reassessed at planned intervals and on significant change
- 8.3: the treatment plan implemented, with results retained

Check your understanding

A company moved its main customer system to a new cloud provider. The last risk assessment was a year before the move.

A Conforming: assessments are only required once a year

B A gap against 8.2: a significant change should trigger reassessment

C A gap against 6.3 only

D Not a concern if the provider is certified

Check your understanding

A company moved its main customer system to a new cloud provider. The last risk assessment was a year before the move.

A. Conforming: assessments are only required once a year

B. A gap against 8.2: a significant change should trigger reassessment

C. A gap against 6.3 only

D. Not a concern if the provider is certified

Answer: B

8.2 requires assessments at planned intervals or when significant changes are proposed or occur. A provider migration is a significant change.

MSM ACADEMY

SECTION 2 · LESSON 2.7

Clause 9: Performance evaluation

2.7

Monitoring and measurement, internal audit, and management review.

LESSON 2.7 · CLAUSE 9.1

9.1 Monitoring, measurement, analysis and evaluation

The organization shall determine (paraphrased)

a) What needs to be monitored and measured, including security processes and controls.

b) The methods, to ensure valid results: comparable and reproducible.

c) When monitoring and measuring shall be performed.

9.1 Monitoring, measurement, analysis and evaluation

…and (paraphrased)

d) Who shall monitor and measure.

e) When the results shall be analysed and evaluated.

f) Who shall analyse and evaluate them.

- Documented information shall be available as evidence of the results.

- Evaluate the security performance and the effectiveness of the ISMS.

9.1 for privileged access

Any organization

The situation

- What: privileged accounts without a review in the last quarter
- Method: automated report from the identity system, same query each time

Applying the requirement

- When: monthly; who: the identity team
- Analysed quarterly by the security manager against a target of zero
- Results kept as dashboards and fed into management review

9.2.1 Internal audit

Conduct internal audits at planned intervals to show whether the ISMS (paraphrased)

a) 1) Conforms to the organization’s own requirements for its ISMS.

a) 2) Conforms to the requirements of the standard.

b) Is effectively implemented and maintained.

9.2.2 Internal audit programme

Plan, establish, implement and maintain an audit programme (paraphrased)

- Including frequency, methods, responsibilities, planning requirements and reporting.

- Consider the importance of the processes and the results of previous audits.

a) Define the audit criteria and scope for each audit.

b) Select auditors and conduct audits to ensure objectivity and impartiality.

c) Ensure results are reported to relevant management.

What 9.2 means

Risk-based frequency

Privileged access management may be audited more often than low-risk administrative tasks.

Objectivity

Auditors do not audit their own work. Full independence is not required; objectivity is.

Criteria and scope

Each audit states what it is checked against and what it covers.

9.3 Management review

What the clause requires (paraphrased)

9.3.1 Top management reviews the ISMS at planned intervals for continuing suitability, adequacy and effectiveness.

- Suitable: still fits the organization. Adequate: enough. Effective: achieving its outcomes.

9.3.2 Management review inputs

The review shall consider (paraphrased)

a) The status of actions from previous reviews.

b) Changes in relevant external and internal issues.

c) Changes in the needs and expectations of relevant interested parties.

d) Feedback on security performance (next slide).

9.3.2 Management review inputs

…and (paraphrased)

d) Performance trends: nonconformities and corrective actions; monitoring and measurement; audit results; objectives.

e) Feedback from interested parties.

f) Results of risk assessment and status of the risk treatment plan.

g) Opportunities for continual improvement.

9.3.3 Management review results

What the clause requires (paraphrased)

- The results shall include decisions on continual improvement opportunities…
- …and any needs for changes to the ISMS.
- Documented information shall be available as evidence of the results.

9.3 in a healthcare provider

Healthcare

The situation

- Inputs: endpoint protection action from last review complete; a new regulator guideline; audit found weak supplier reviews
- Phishing objective missed; two High risks still untreated

Applying the requirement

- Decision: fund a supplier-assurance role
- Decision: extend the phishing objective with targeted training
- Change: bring the new guideline into scope requirements
- Minutes record each decision with an owner and date

Evaluation: two perspectives

Clause 9: evidence about the ISMS itself.

Implementer's view

- Measure what shows whether security works
- Plan audits by importance and past results
- Keep auditors objective
- Bring every input to the review, and record decisions

Auditor's view

- Are measures defined, run and evaluated?
- Does the audit programme cover the ISMS over time?
- Are auditors objective?
- Did top management review it and decide?

Clause 9: common challenges

Where organizations go wrong

1. Lots of data collected, but never analysed or evaluated.
2. Internal audits that check documents, not effectiveness.
3. Auditors auditing their own work.
4. Management reviews that miss required inputs or record no decisions.

LESSON 2.7 · RECAP

Clause 9 recap

- 9.1: what, how, when and who for measurement and evaluation; results kept
- 9.2: a planned, objective audit programme covering conformity and effectiveness
- 9.3: top management reviews every input and records decisions

Check your understanding

The management review minutes summarize audit results and incidents, but record no decisions or actions.

A Conforming: the review considered performance

B A gap against 9.3.3: results must include decisions

C A gap against 9.2: audits must be reviewed by auditors

D Conforming if the minutes are signed

Check your understanding

The management review minutes summarize audit results and incidents, but record no decisions or actions.

A. Conforming: the review considered performance

B. A gap against 9.3.3: results must include decisions

C. A gap against 9.2: audits must be reviewed by auditors

D. Conforming if the minutes are signed

Answer: B

9.3.3 requires the results to include decisions on improvement opportunities and any needed changes. A summary alone falls short.

MSM ACADEMY

SECTION 2 · LESSON 2.8

Clause 10: Improvement

Continual improvement, nonconformity and corrective action.



10.1 Continual improvement

What the clause requires (paraphrased)

- Continually improve the suitability, adequacy and effectiveness of the ISMS.

- Inputs come from across the system: monitoring, audits, incidents, risk assessments, management review.

10.1 after a ransomware test

Manufacturing

The situation

- A recovery exercise shows backups restore, but too slowly for the production lines
- No nonconformity: requirements were met

Applying the requirement

- The management review decides to improve the recovery design
- Faster restore tests and an updated recovery plan
- Improvement without anything having gone wrong

10.2 Nonconformity and corrective action

When a nonconformity occurs, the organization shall (paraphrased)

a) React: as applicable, control and correct it, and deal with the consequences.

b) Evaluate the need for action to eliminate its causes, so it does not recur or occur elsewhere.

c) Implement any action needed.

d) Review the effectiveness of any corrective action taken.

e) Make changes to the ISMS, if necessary.

10.2 b) Getting to the cause

Evaluating the need for action, by

1) Reviewing and analysing the nonconformity.

2) Determining its causes.

3) Determining whether similar nonconformities exist, or could potentially occur.

Nonconformity and incident are not the same



Nonconformity

A requirement not fulfilled: of the standard, or of the organization’s own ISMS.



Security incident

An unwanted event affecting information. Handled by the incident process.



How they connect

An incident may reveal a nonconformity. It does not automatically trigger 10.2.

10.2 after an internal audit finding

Financial services

The situation

- Audit finds quarterly access reviews were not done for six months
- The reviewer left; nobody took over the task

Applying the requirement

- a) Run the overdue review now; remove inappropriate access
- b) Cause: tasks not reassigned when people leave; check other recurring tasks
- c)–d) Add task handover to the leaver process; verify next quarter
- e) Update the procedure; record the nonconformity and actions

10.2 Documented information

Documented information shall be available as evidence of

f) The nature of the nonconformities and any subsequent actions taken.

g) The results of any corrective action.

Improvement: two perspectives

Clause 10: fix the cause, then prove it worked.

Implementer's view

- Correct quickly, then look for the cause
- Check for the same problem elsewhere
- Verify that corrective action worked
- Keep incident and nonconformity processes distinct but linked

Auditor's view

- Was the cause identified, not just the symptom?
- Was the wider search for similar cases done?
- Is there evidence the action was effective?
- Does the ISMS improve over time?

Clause 10: common challenges

Where organizations go wrong

1. Correction only: the symptom fixed, the cause left in place.
2. Actions closed without checking they worked.
3. Every incident logged as a nonconformity, or none ever is.
4. Improvement that happens only when an auditor asks for it.

LESSON 2.8 · RECAP

Clause 10 recap

- 10.1: continual improvement of suitability, adequacy and effectiveness
- 10.2: react, find causes, act, check effectiveness, change the ISMS if needed
- A nonconformity is not the same as an incident; records show the actions and results

Check your understanding

A phishing email was reported and blocked. Every control worked as designed. The manager wants to raise a nonconformity.

A Required: every incident is a nonconformity

B Not required: no requirement was unfulfilled; the incident process applies

C Required only if the incident was reported late

D Not required, because phishing is outside the ISMS

Check your understanding

A phishing email was reported and blocked. Every control worked as designed. The manager wants to raise a nonconformity.

A. Required: every incident is a nonconformity

B. Not required: no requirement was unfulfilled; the incident process applies

C. Required only if the incident was reported late

D. Not required, because phishing is outside the ISMS

Answer: B

A nonconformity is a requirement not fulfilled. Here every control worked: it is an incident handled by the incident process.

Clauses 4–10 in one view

Plan	Do	Check	Act
4, 5, 6	**7, 8**	**9**	**10**
Context, scope, leadership, risk, objectives	Resources, competence, documents; operation and risk work	Measurement, internal audit, management review	Corrective action and continual improvement

Every requirement connects: context drives risk, risk drives controls and objectives, evaluation drives improvement.

SECTION 2 COMPLETE

Next: Section 3

Annex A: the 93 information security controls, theme by theme.

